

A Continuous Authentication Technique for XR Utilizing Time-Based One Time Passwords, Haptics, and Kinetic Activity

Jerônimo G Grandi ^{*} Jerry Terrell [†] Kadir Lofca [‡] Carlos Ruizvalencia [§] Regis Kopper [¶]

University of North Carolina at Greensboro

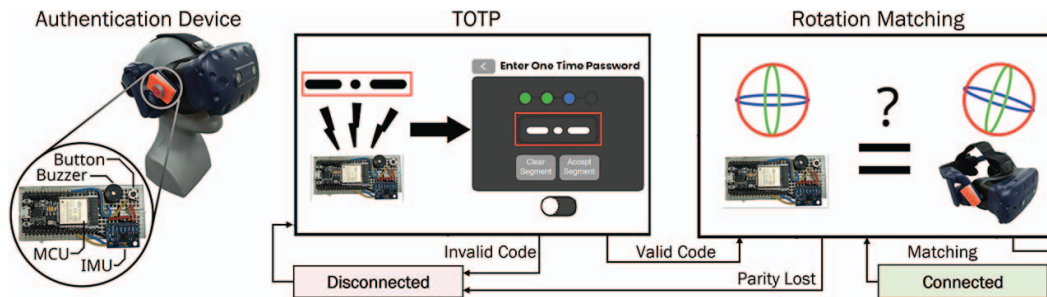


Figure 1: Design and electrical authentication device prototype (on the left) and overview of authentication procedure (on the right).

ABSTRACT

Authentication in Extended Reality (XR) applications typically requires the user to enter a pattern or traditional password into an adapted two-dimensional UI or to enter information from outside the XR environment such as a pairing code on a mobile device. The existing solutions are far from ideal due to the inconvenience of repeatedly exiting and entering the XR environment to transfer codes, the risk associated with relying on static passwords, and the vulnerability caused by only authenticating at the start of the session. We present an authentication method developed for XR that offers robust security and an uninterrupted user experience. Our method uses a web-connected device able to generate time-based one-time passwords (TOTP) via haptics and maintain continuous authentication by tracking the user's kinetic activity. We refer to this theoretical device as the authentication device and emulate it for this paper using either an XR tracker or a networked microcontroller with an attached IMU.

Index Terms: Human-centered computing—Human computer interaction (HCI)—Interaction paradigms—Virtual reality; Security and privacy—Security services—Authentication—Graphical / visual passwords; Human-centered computing—Human computer interaction (HCI)—Interaction devices—Haptic devices

1 INTRODUCTION

With an increasing public interest in XR applications, there is a higher demand for better authentication methods. If left unattended, sensitive information that is protected in other commonly used devices such as mobile phones and computers will be vulnerable to attacks. This is further exacerbated by the innate vulnerabilities that VR head-mounted displays (HMDs) present since the user is essentially blinded to the real environment while wearing the HMD [10].

The usability of authentication mechanisms in XR is especially challenging because the symbolic input required to enter passwords is typically unnatural with three-dimensional (3D) input. A new authentication method cannot be overly complicated, otherwise, it will not be widely adopted. Cumbersome methods might result in high error rates and longer authentication times, leaving a legitimate user frustrated and, in extreme cases, being completely locked out of their own device [10].

Despite the advancements in XR technology, authentication as part of the user experience has been largely overlooked [2]. Traditional password authentication methods only verify the user's identity once, when the session starts, and do not continuously verify identity for the entire duration of the session. With an increasing need for personal information security, there is an opportunity to utilize the capabilities of XR devices for designing intuitive and secure authentication methods.

Our primary goal is to leverage XR device features such as kinetic data and haptics to offer a high degree of security to users, comparable to that offered by modern non-XR devices. Our method uses a continuous authentication scheme that is robust against exploitation of the known TOTP vulnerability that an authenticated session can be hijacked by a malicious party [7]. This approach ensures a more robust and secure experience by constantly monitoring behavioral parameters to detect whether the initially authenticated individual using a computing system is the same individual who was authenticated at the start of a session. This is achieved without disrupting the user experience. Fig. 1 shows the authentication process.

Continuous authentication techniques rely on attributes of the verified user's interactions and behavioral patterns to assert the user's identity throughout the session. Existing continuous authentication techniques use information derived from user-generated data, such as touch-based biometrics [9], eye-gaze [5], face biometrics [1] and head movements [3]. Specifically for the XR context, Mustafa et al. [6] and Liebers et al. [4] used head and body movement patterns for continuous authentication in VR. While our approach also uses behavioral metrics, the main difference is in how continuous authentication is achieved. In our solution, we use an external authentication device to provide an extra security layer during the authentication process. Kinetic activity from both the HMD and the authentication device is continually transmitted to a remote server that matches the rotational data, establishing parity between both devices to ensure authentication throughout the XR session.

^{*}e-mail: jggrandi@uncg.edu

[†]e-mail: jlterrell@uncg.edu

[‡]e-mail: k.lofca@uncg.edu

[§]e-mail: cmruizva@uncg.edu

[¶]e-mail: kopper@uncg.edu

2 TWO-PHASE XR AUTHENTICATION

Our proposed authentication method is achieved in two phases: (1) an initial one-time password and (2) continuous authentication until the user logs out of their account or until the rotational data parity from HMD and the authentication device is lost. The authentication device is portable and lightweight and can be easily attached to any HMD for secure authentication.

2.1 First Phase: Time-Based One Time Passwords

The first phase of the proposed solution requires the system to generate a Morse code-like TOTP that is shared with the user by the authentication device's haptic motor. Haptics is difficult for a surface attacker to detect as the vibration pattern cannot be observed without touching the authentication device itself. Previous work has explored Morse code-based authentication keys generated for computer clouding [8]. Unlike an alphabet, where the pronunciation of characters/ letters differs phonetically, it is possible to efficiently communicate Morse code using long vibrations and short vibrations, making it a well-suited method of haptics-based OTP.

The generated Morse-like code contains 4 parts, and in each part there are 1 to 4 digits (dot or dash). The user must confirm each part before proceeding to the next one. The authentication device will only reveal the code for the current part, and the user is not required to memorize codes as the authentication device will periodically repeat the current part's code. The haptic feedback can be easily perceived by the user in the form of dots and dashes. During this phase, the experience is uninterrupted since the user keeps wearing the HMD during the entire authentication process. The user enters the OTP using a series of long and short button presses on the XR controller. The system provides visual confirmation of the symbols entered to ensure accuracy and allows the user to correct any mistakes by re-entering each part (Fig. 1, TOTP box).

2.2 Second Phase: Continuous Authentication

The continuous authentication phase starts after the Morse code-like TOTP is validated. While still in the virtual lobby, the system samples rotational data from both the authentication device and the HMD for a predetermined period to ensure that they are matching, see Fig. 1, Rotation Matching box. Once a sufficient level of confidence that rotations from both devices are matching, the system automatically loads the main virtual environment. The authentication system continuously monitors the rotational data in the background, and the user's connection remains active as long as the rotational difference remains below the established threshold. If the rotational parity is lost, the user receives a notification and has a specific time frame to restore the rotational consistency between the HMD and the authentication device. If the rotational consistency is not re-established, the user is logged out.

3 DISCUSSION

Many users are already familiar with time-based one-time passwords (TOTP) as they are used in many two-factor login procedures for traditional applications [11]. In those scenarios, an app on a personal device generates a combination of decimal numbers that must be entered into the application, and the numbers change at a constant rate of time (e.g., every 30s). Our solution uses the same concept, except that we use symbols inspired by Morse code instead of digits that change every minute. Another key difference in our solution is the absence of a standard password that usually accompanies a TOTP. We purposely exclude such a password because entering it in a virtual environment would add extra challenges. Given that each segment of the generated haptic TOTP can contain up to 4 pulses and that there are 4 segments in a password, we can compute the total password parity as follows:

$$\left(\sum_{n=1}^4 2^n\right)^4 = 810,000.$$

This is nearly as good as a 6 digit decimal password with a parity of 1,000,000, although our implementation of TOTP alone is less secure than traditional two factor logins.

Improving the security of our solution further could impact usability. Instead, we rely on two principles to explain the security of our solution. First, the authentication device must be powered on by the user for them to log in. This prevents the vast majority of fraudulent login attempts. Second, the server-side implementation should throttle the number of login attempts. Additionally, continuous authentication using behavioral activity data offers protection against session hijacking by constantly monitoring the unique behavior patterns associated with the authorized user and detecting any deviations from those patterns. This enhances the authentication process by providing a reliable and efficient way to detect and prevent login attempts by unauthorized users.

4 CONCLUSION

In this paper, we have proposed a new hybrid authentication scheme that uses TOTP for initial authentication and a continuous authentication method to prevent session hijacking. We strived to achieve a balance between usability and high security. An interesting research question is whether increasing the length of the code at the initial phase would be worth the usability cost, or would it prove too cumbersome for the average user and increase error rates to an unacceptable degree. Another area of research to consider is the potential to streamlining the authentication process by eliminating the use of TOTP and relying instead solely on the user's behavioral patterns obtained through the continuous authentication method. Finally, one limitation of our approach is that it cannot detect if a different person switches the HMD with the authenticated user while the authentication device remains connected and attached to the HMD. This can be addressed by disconnecting the session when the HMD is removed, or by detecting unnatural HMD movement patterns.

REFERENCES

- [1] M. E. Fathy, V. M. Patel, and R. Chellappa. Face-based active authentication on mobile devices. In *Proc. ICASSP*. IEEE, 2015.
- [2] P. Kürtünlioğlu, B. Akdik, and E. Karaarslan. Security of virtual reality authentication methods in Metaverse: An overview, 2022.
- [3] S. Li, A. Ashok, Y. Zhang, C. Xu, J. Lindqvist, and M. Gruteser. Whose move is it anyway? Authenticating smart wearable devices using unique head movement patterns. In *Proc. IEEE PerCom*, 2016.
- [4] J. Liebers, M. Abdelaziz, L. Mecke, A. Saad, J. Auda, U. Gruenefeld, F. Alt, and S. Schneegass. Understanding user identification in virtual reality through behavioral biometrics and the effect of body normalization. In *Proc. CHI 2021*, 2021.
- [5] K. Mock, B. Hoanca, J. Weaver, and M. Milton. Real-time continuous iris recognition for authentication using an eye tracker. In *Proc. ACM CCF*, 2012.
- [6] T. Mustafa, R. Matovu, A. Serwadda, and N. Muirhead. Unsure how to authenticate on your VR headset? Come on, use your head! In *Proc. IWSPA*, 2018.
- [7] P. J. N. I. Neil Haller, Craig Metz and M. Straw. A One-Time Password System. RFC 2289, RFC Editor, 1998.
- [8] M. Yadav and M. Breja. Secure dna and morse code based profile access control models for cloud computing environment. In *Proc. ICCIDS*, 2019.
- [9] Y. Yang, B. Guo, Z. Wang, M. Li, Z. Yu, and X. Zhou. Behavesense: Continuous authentication for security-sensitive mobile apps using behavioral biometrics. *Ad Hoc Networks*, 84:9–18, 2019.
- [10] H. Zhu, W. Jin, M. Xiao, S. Murali, and M. Li. Blinkkey: A two-factor user authentication method for virtual reality devices. *IMWUT*, 2020.
- [11] D. M'Raihi, S. Machani, M. Pei, and J. Rydell. TOTP: Time-Based One-Time Password Algorithm. RFC 6238, RFC Editor, May 2011.